

TAXSYNC

Technical Documentation

Smart Document Management and Compliance
Platform for Indian Regulatory Practice

PRODUCT VERSION

v2.0.1

DOCUMENT DATE

8 May 2026

STATUS

Production-Ready

PRODUCTION FEATURES

64 features across 9 areas

TEST COVERAGE

389 automated tests

This document describes the production-shipped capability of the TaxSync platform.

TaxSync — Technical Documentation

Version: v2.0.1 **Document date:** 8 May 2026 **Audience:** CA firms, finance teams, compliance leadership, and technology evaluators

Table of Contents

1. [Executive Summary](#)
 2. [Product Overview](#)
 3. [System Architecture](#)
 4. [Technology Stack](#)
 5. [Feature Catalog](#)
 6. [AI and Machine Learning Pipeline](#)
 7. [Compliance Notice Lifecycle](#)
 8. [Email Integration](#)
 9. [Notifications and Alerts](#)
 10. [Security and Compliance](#)
 11. [Role-Based Access Control](#)
 12. [Statutory Calendar](#)
 13. [API Reference](#)
 14. [Deployment Architecture](#)
 15. [Performance and Reliability](#)
 16. [Quality Assurance](#)
 17. [Glossary](#)
-

1. Executive Summary

TaxSync is a smart document and compliance management platform built specifically for Indian tax practitioners, Chartered Accountant (CA) firms, in-house finance teams, and individuals managing regulatory paperwork. It combines an intelligent document library with end-to-end compliance notice management — from intake (manual upload or automatic Gmail capture), through classification and risk scoring, to drafting, approval, escalation, and tracking.

Core value proposition. TaxSync replaces fragmented workflows — inbox triage, spreadsheet trackers, manual deadline calendars, and ad-hoc approval chains — with a single multi-tenant platform that automatically captures regulatory notices, classifies and risk-scores them with explainable AI, routes them through a configurable approval workflow, and ensures no statutory deadline is ever missed.

Production status. The platform is production-ready: 64 user-facing features are live across 9 functional areas, backed by 389 backend automated tests, comprehensive security hardening, and continuous deployment infrastructure.

2. Product Overview

2.1 What TaxSync Is

A unified web application that brings together:

- **Intelligent document library** — upload, OCR, classify, extract metadata, search, share, and version-control any document.
- **Compliance notice management** — track every regulatory notice (GST, Income Tax, MCA, RBI, SEBI) end-to-end with risk scoring and approval workflows.
- **Statutory calendar** — 37 pre-loaded FY 2025-26 deadlines, holiday-aware adjustment, and a rolling compliance health score.
- **Email-driven intake** — Gmail integration that continuously imports compliance notices and household bills.
- **Multi-tenant management** — CA firms manage many client entities with strict cross-client isolation.

2.2 Target Users

User profile	Primary use
CA firms and consultants	Managing many client entities, multi-client triage, response drafting, audit-ready documentation
In-house finance and compliance teams	Notice tracking, approval workflows, statutory calendar, regulator-facing audit trails
Solo practitioners	Personal document library, bill tracking, regulator-notice intake
External auditors	Time-bound, read-only access to notices and audit history for assurance work
Individuals	Personal document management, household bill reminders

2.3 Product Surface

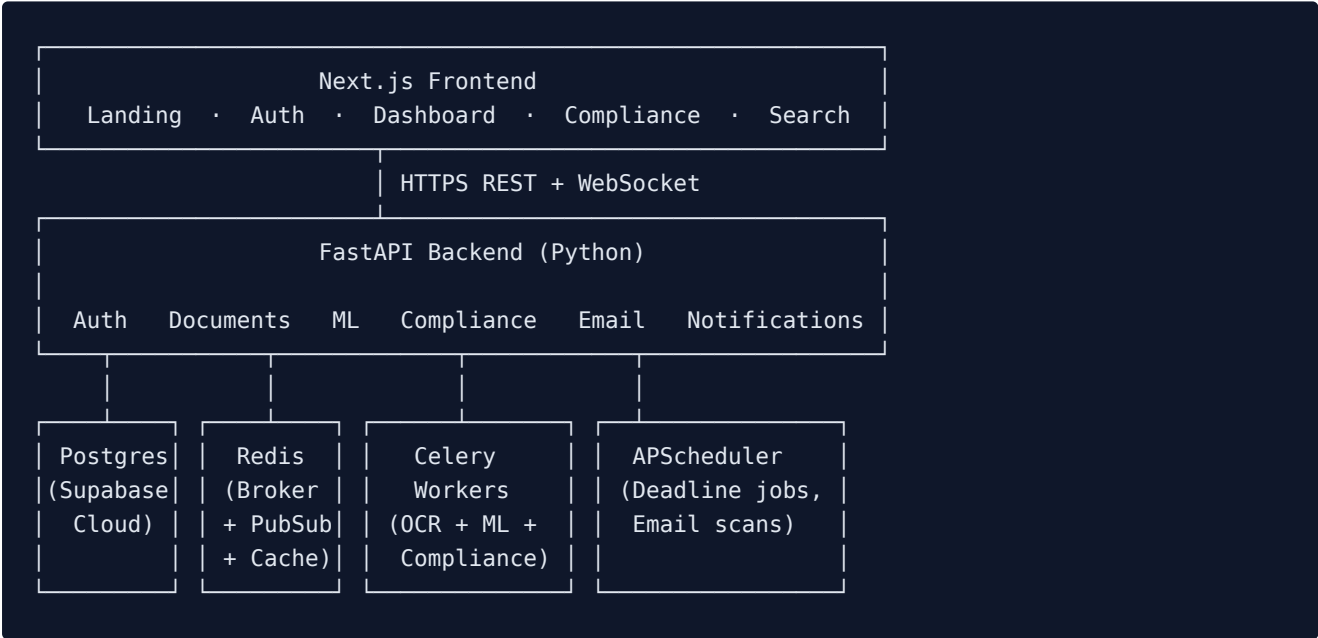
The product is organized into nine functional areas:

1. Document Management
2. Compliance Notice Management
3. Statutory Calendar and Alerts
4. Email Integration (Gmail)
5. Bills and Payments
6. AI Document Intelligence
7. Search and Reporting
8. Multi-User Access and Security
9. Analytics and Reporting

Each area is documented in detail in Section 5: Feature Catalog.

3. System Architecture

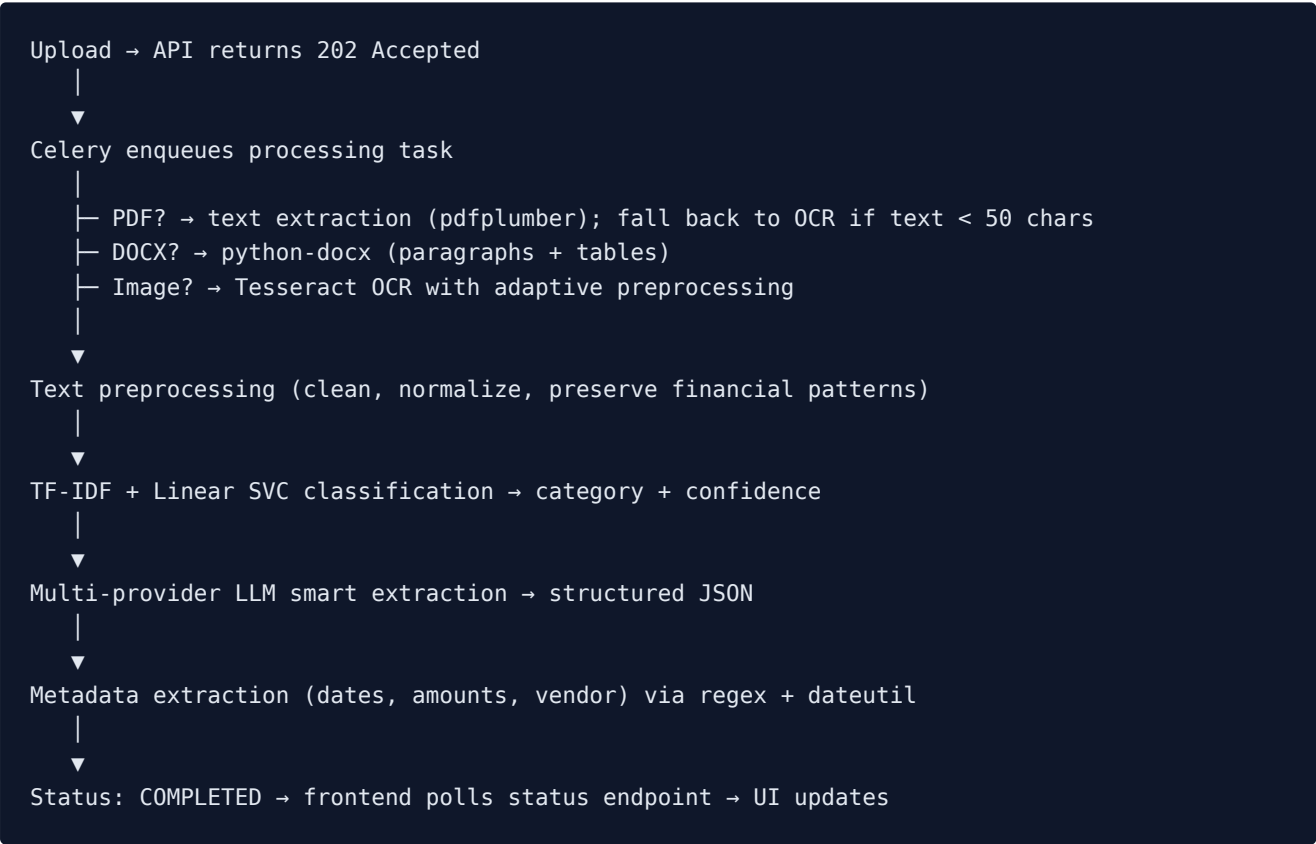
3.1 High-Level Architecture



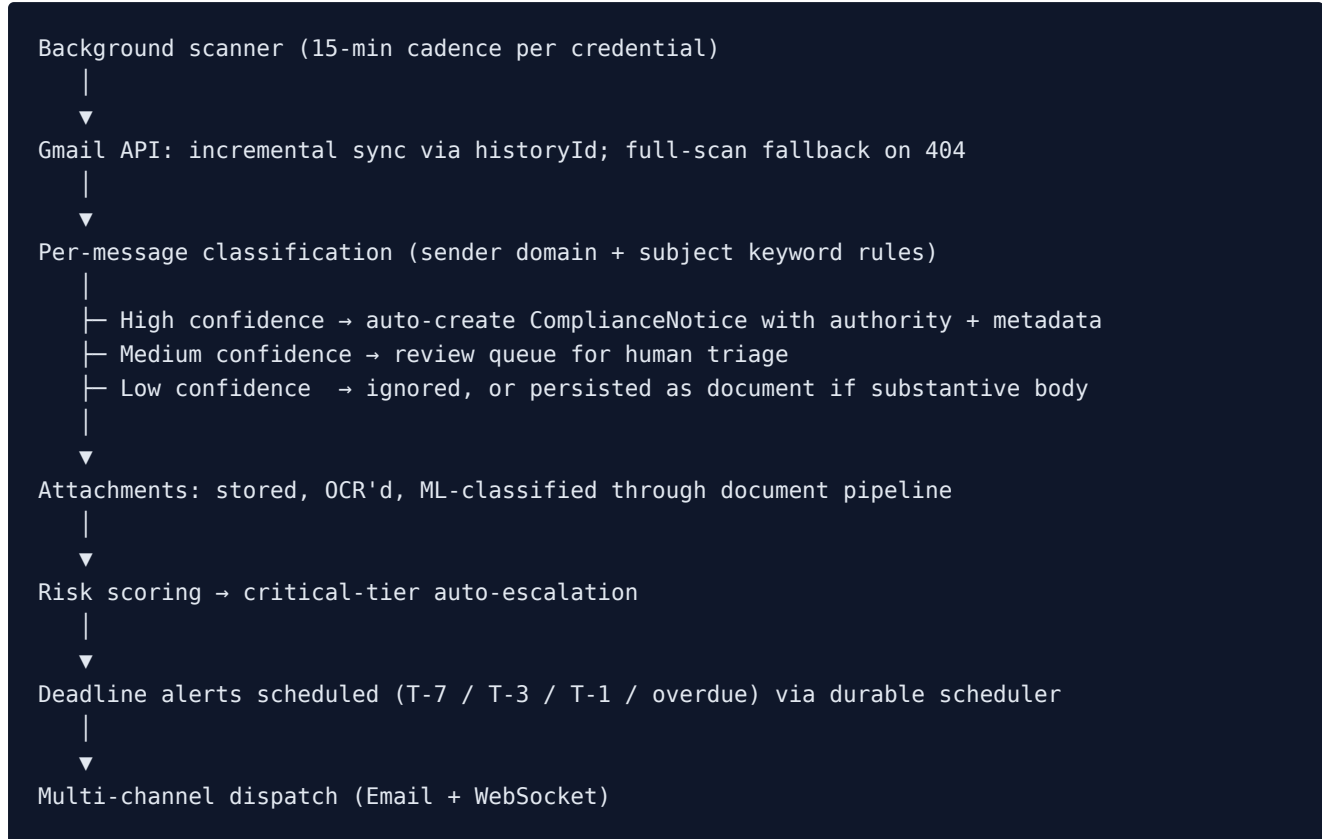
3.2 Component Topology

Component	Responsibility
Frontend	Single-page application, server components, client-side state, real-time WebSocket subscriptions
API Gateway	REST endpoints, JWT authentication, rate limiting, request validation, audit logging
Document Worker	OCR, text extraction, ML classification, metadata extraction, AI summary generation
Compliance Worker	Risk scoring, escalation logic, response state transitions, alert dispatch
Scheduler	Deadline-driven alerts (T-7, T-3, T-1, overdue), Gmail polling, statutory calendar refresh
Database	Persistent state with row-level security and immutable audit logs
Object Storage	Original document files (local volume in development; S3-compatible in production)
Message Broker	Task queue and pub/sub channel for real-time notifications

3.3 Data Flow — Document Ingestion



3.4 Data Flow — Compliance Notice (Email-Driven)



3.5 Multi-Tenancy Model

TaxSync uses a single-database, RLS-enforced multi-tenant model:

- Every client-scoped table (`compliance_notices` , `notice_activity` , `notice_alert_log` , `client_memberships` , `responses` , etc.) has a `client_id` foreign key.
- PostgreSQL Row-Level Security (RLS) policies are applied with `FORCE ROW LEVEL SECURITY` on every client-scoped table.
- The application connects to PostgreSQL as a runtime role (`app_runtime`) that has `REVOKE` rights on the `audit_logs` table — meaning even the application cannot bypass audit immutability.
- Tenant context (the active `client_id`) is injected per-request from a custom HTTP header (`X-Client-Id`) and propagated into PostgreSQL via session-level `SET` statements.
- A `cross_client_view` PERMISSIVE policy lets senior roles (Compliance Head, CA Consultant, CFO) see aggregated views across the clients they belong to, without leaking unauthorized clients.

This model is stronger than application-layer scoping because a missed `WHERE client_id = ...` clause in code cannot leak data — the database itself filters every row.

4. Technology Stack

4.1 Frontend

Capability	Technology
Framework	Next.js 15 (App Router, standalone build)
UI library	React 19
Language	TypeScript
Styling	Tailwind CSS
Server-state	TanStack Query v5
Client-state	Zustand v5 (with persist middleware for multi-tenant state)
Forms	React Hook Form v7 + Zod v3 schema validation
Tables	TanStack Table v8 (notice list with row selection)
Date pickers	react-day-picker v9 (React 19 compatible)
CSV parsing	PapaParse v5
Date utilities	date-fns v3
Animation	Framer Motion
Charts	Recharts
PDF preview	react-pdf

4.2 Backend

Capability	Technology
Web framework	FastAPI
ORM	SQLAlchemy
Validation	Pydantic v2
ASGI server	Uvicorn
Structured logging	structlog (with PII redaction)
Background tasks	Celery (default queue + dedicated compliance queue)
Scheduled jobs	APScheduler with PostgreSQL JobStore
Rate limiting	slowapi (Redis-backed with in-memory fallback)
Migrations	Alembic
Testing	pytest (389 backend tests), pytest-freezer, freezegun

4.3 Data Layer

Capability	Technology
Primary database	PostgreSQL 16 (managed via Supabase Cloud, session-mode pooler)
Cache and broker	Redis 7 (Celery message broker, pub/sub channel for real-time, rate limiter)
Object storage	Local filesystem in development; S3-compatible in production
Full-text search	PostgreSQL <code>tsvector</code> + GIN indexes + <code>pg_trgm</code> trigram fuzzy matching

4.4 AI and Machine Learning

Capability	Technology
Document classifier	Linear SVC + Calibrated Classifier with TF-IDF (15K vocabulary, n-grams up to trigrams)
Classification accuracy	85.06% (exceeds 85% target on held-out evaluation)
OCR engine	Tesseract with adaptive preprocessing pipeline
PDF text extraction	pdfplumber with OCR fallback
DOCX extraction	python-docx (paragraphs + tables)
Named-entity recognition	spaCy (regulatory entity extraction)
Risk scoring	Rule-based scorer with SHAP-style explainable factors
LLM smart extraction	Multi-provider abstraction with automatic fallback (local Ollama, cloud LLMs, regex fallback)
Training datasets	7 datasets totaling ~28 GB (UPI Transactions 2024, Bank Statements, ITR Form 16 images, Invoice OCR, RVL-CDIP, Financial Images India, synthetic augmentation)

4.5 Authentication and Security

Capability	Technology
Access tokens	JWT (HS256, 30-minute expiry) with <code>jti</code> claims
Refresh tokens	Opaque, with rotation and reuse detection
Password hashing	bcrypt (passlib)
Single sign-on	Google OAuth 2.0, Microsoft OAuth 2.0 with CSRF state parameter
Sensitive-field encryption	Fernet symmetric encryption (GSTIN, PAN, refresh tokens at rest)
Email service	Resend SMTP (configurable to any SMTP provider)
Rate limiting	Redis-backed slowapi with in-memory fallback

4.6 Infrastructure

Capability	Technology
Containerization	Docker Compose (db, redis, backend, default worker, compliance worker, frontend)
Frontend hosting	Vercel (production)
CI/CD	GitHub Actions (automated tests, linting, Docker image build)
Dependency monitoring	Dependabot
Logging	JSON-structured logs with correlation IDs, 10MB rotation per container
Health checks	Per-service Docker healthchecks with start_period and retry policies

5. Feature Catalog

This catalog organizes all 64 production features by user need.

5.1 Document Management (10 features)

ID	Feature	Description
A1	Universal upload	PDF, DOCX, JPEG, PNG, TIFF up to 16 MB, single or batch
A2	OCR for scans and images	Reads text from photographs, scanned documents, blurred or skewed images
A3	Auto-categorization	Sorts documents into 7 categories (Bills, Invoices, Tax, Bank, UPI, Tickets, Other) at ~85% accuracy
A4	Smart field extraction	Automatically pulls vendor, date, and amount from documents
A5	AI-generated summaries	One-paragraph plain-English summary per document
A6	Document sharing with roles	Viewer / Editor / Admin permissions per document
A7	Version control with rollback	Auto-versioning on re-upload; restore any historical version
A8	In-browser preview	PDF and image preview with page navigation, zoom, and pan
A9	Full-text search	Search across document content (not just filenames) with fuzzy matching
A10	Document analytics dashboard	Upload trends, category distribution, processing status

5.2 Compliance Notice Management (12 features)

ID	Feature	Description
B1	Multi-client tracking	CA firms manage many client entities; each with its own GSTIN/PAN/CIN
B2	Three intake modes	Drag-and-drop, manual metadata, or automatic Gmail capture
B3	Auto-classification by authority	GST, Income Tax, MCA, RBI, SEBI identified from sender + content
B4	Risk scoring with explainable factors	0-100 score, Critical/High/Medium/Low tier, top 3 driving factors in plain English
B5	Status workflow	Received → Under Review → Response Drafted → Submitted → Resolved/Dismissed
B6	Linked notice chains	Show-Cause → Assessment → Demand modeled as parent-child notice tree
B7	4-stage approval workflow	Drafter → Reviewer → Legal → CFO with version history
B8	Auto-escalation for Critical notices	Compliance Head notified instantly via in-app + email
B9	Bulk status updates	Move many notices through a stage in one action with partial-failure UX
B10	Time-bound auditor access	External auditors get read-only access until configured expiry date
B11	Immutable audit trail	Every action logged in tamper-proof, append-only record
B12	7-role permission matrix	12 permissions × 7 roles, plus time-bound Auditor role

5.3 Statutory Calendar and Alerts (6 features)

ID	Feature	Description
C1	37 pre-loaded FY 2025-26 deadlines	GSTR-1, GSTR-3B, GSTR-9, TDS quarterly returns, Advance Tax, ITR, MCA returns
C2	Holiday-aware deadline shifting	Sundays and gazetted holidays shift to next working day automatically
C3	Real-time in-app notifications	Live notification bell with auto-reconnecting WebSocket
C4	Email alerts	T-7, T-3, T-1 reminders for every notice and deadline
C5	Compliance health score	Single percentage over rolling 90-day window per client
C6	Bill reminders	T-3, T-1, overdue reminders for utility / telecom / OTT / credit card bills

5.4 Email Integration — Gmail (7 features)

ID	Feature	Description
D1	One-click Gmail connect	OAuth 2.0 with offline access for refresh tokens
D2	Continuous background scanning	15-minute cadence per credential, configurable from 5 minutes to 24 hours
D3	Filter rules	Route to compliance / bills / document-only / ignore based on sender, subject, label
D4	Auto-detect regulatory emails	gov.in domains and known authority senders auto-create notices
D5	Auto-detect bills	Utility, telecom, credit card, OTT subscription emails captured as bill records
D6	View source email on demand	Original email body fetched on request, never stored on disk
D7	Connection health monitoring	"Reconnect required" banner on token revocation; email alert after 2 consecutive failures

5.5 Bills and Payments (6 features)

ID	Feature	Description
E1	Bill dashboard with filters	Upcoming / Due Soon / Overdue / Paid buckets with category aggregates
E2	Pre-deadline reminders	T-3, T-1, overdue with cap of three reminders per bill
E3	Mark as paid	Track payment date, reference number, method with audit log entry
E4	Recurring bill detection	Auto-link by biller and last 4 of account number; series view with monthly/quarterly/annual
E5	Missing-month anomaly detection	Surface bills that should have arrived but didn't
E6	Multi-channel reminder delivery	Email + in-app bell

5.6 AI Document Intelligence (6 features)

ID	Feature	Description
F1	Auto-classification across 7 categories	~85% accuracy with manual override
F2	Multi-provider LLM with automatic fallback	Local-first (Ollama) with cloud fallback; provider outages are silent
F3	Smart extraction (dates, amounts, vendors)	Structured JSON output
F4	AI-generated summaries	Plain-English one-paragraph summary per document
F5	Risk scoring for compliance notices	0-100 score with explainable factors
F6	Human review queue for low-confidence ML output	Prevents miscategorization on uncertain inputs

5.7 Search and Reporting (6 features)

ID	Feature	Description
G1	Full-text search across documents	PostgreSQL tsvector with relevance ranking
G2	Cross-entity unified search	Single query across documents and compliance notices with type badges
G3	Fuzzy matching	Typo tolerance via pg_trgm trigram similarity
G4	Filter by authority, status, risk, date	Combinable filters with shareable URL state
G5	Pre-built reports	Penalty by Authority, Notice Volume by Status, Response Time Percentiles, Health Summary
G6	CSV export of every report	Downloads to Excel or Google Sheets format

5.8 Multi-User Access and Security (8 features)

ID	Feature	Description
H1	Email and password sign-in	Standard registration with strong password requirements
H2	Single sign-on	Google and Microsoft OAuth
H3	7 compliance roles + Auditor	Compliance Head, CA Consultant, CFO, Drafter, Reviewer, Legal Team, Finance Team, Auditor
H4	Cross-client view for senior roles	Aggregated dashboard across multiple clients for owners and consultants
H5	Admin user management	Invite, assign roles, revoke access from a Team page
H6	Auto-logout and session management	Refresh on activity; automatic sign-out after inactivity
H7	Encrypted sensitive fields	GSTIN, PAN, refresh tokens encrypted at rest with Fernet
H8	Production security hardening	Rate limiting, security headers, CSRF protection, magic-byte file validation

5.9 Analytics and Reporting (6 features)

ID	Feature	Description
I1	Documents dashboard	Total count, monthly upload trends, category breakdown
I2	Compliance dashboard with risk distribution	Pie chart of notices by risk tier, monthly volume, status snapshot
I3	Compliance health score	Rolling 90-day percentage prominently displayed per client
I4	Per-authority penalty totals	Bar chart of total penalty amounts by regulator
I5	Notice response time analytics	Median, 75th percentile, 90th percentile response times
I6	CSV export of every report	Universal export across all dashboards

6. AI and Machine Learning Pipeline

6.1 Document Processing Pipeline

Every uploaded document flows through a deterministic pipeline that combines deterministic text extraction with ML inference and AI smart extraction:


```

Upload (HTTP 202 Accepted)
|
▼
Celery worker picks up task
|
├─ PDF? → pdfplumber text extraction
│   └─ if text < 50 chars, fall back to OCR
├─ DOCX? → python-docx (paragraphs + tables)
├─ Image? → Tesseract OCR
│   └─ Grayscale → Gaussian blur → Adaptive threshold
│       └─ Deskew correction
│           └─ Morphological open/close
│               └─ Multi-PSM retry (PSM 6 → PSM 3)
|
▼
Text preprocessing (clean, normalize, preserve financial patterns)
|
▼
TF-IDF + Linear SVC classification → category + confidence score
|
▼
Multi-provider LLM smart extraction
(category-specific prompts → structured JSON)
|
▼
Metadata extraction (dates, amounts, vendor – regex + dateutil)
|
▼
Persist: status COMPLETED, category, confidence, AI summary, structured fields

```

6.2 Document Classifier

- **Algorithm:** Linear Support Vector Classifier wrapped in a Calibrated Classifier for probability estimates
- **Features:** TF-IDF vectorization with 15,000-term vocabulary, n-grams up to trigrams
- **Class balance:** Synthetic data augmentation (factor=10) on the smaller categories
- **Held-out accuracy:** 85.06% (exceeds 85% target)
- **Per-category metrics:** Precision/Recall/F1 visible in the in-app ML evaluation dashboard with confusion matrix
- **Model artifacts:** Versioned in source control for reproducible deployment; no training step required at deploy time

6.3 OCR Pipeline

The OCR engine handles scanned PDFs, phone-camera photographs, and low-quality images. Adaptive preprocessing improves Tesseract output significantly compared to a naive pipeline:

Stage	Operation	Purpose
1	Grayscale conversion	Reduces channel count, improves edge detection
2	Gaussian blur	Smooths sensor noise without losing strokes
3	Adaptive thresholding	Binarizes under varying lighting (better than fixed threshold)
4	Deskew correction	Rotates skewed scans within $\pm 45^\circ$
5	Morphological open/close	Cleans speckle and joins broken strokes
6	Multi-PSM retry	If PSM 6 (uniform block) yields low confidence, retry with PSM 3 (auto layout)

6.4 LLM Smart Extraction

A multi-provider abstraction lets the system route LLM calls across:

- **Local-first (Ollama)** for privacy-sensitive deployments and zero per-call cost
- **Cloud LLM providers** for higher-quality extraction when latency budget allows
- **Regex fallback** so the pipeline degrades gracefully if all LLM providers are unreachable (the system tracks degraded-mode runs in its metrics)

Category-specific prompts produce structured JSON output (vendor, date, amount, account number, deadline, notice number, authority) that flows directly into the database without manual parsing.

6.5 Risk Scoring with Explainable Factors

Each compliance notice receives:

- A 0-100 numeric risk score
- A risk tier label (Critical / High / Medium / Low)
- The top 3 explainable factors driving the score, in plain English

Example: "Penalty over Rs. 5L", "Deadline within 7 days", "Senior authority (CGST Commissioner)". The factor list is generated in a SHAP-style additive decomposition, so users can trust the score is not a black box.

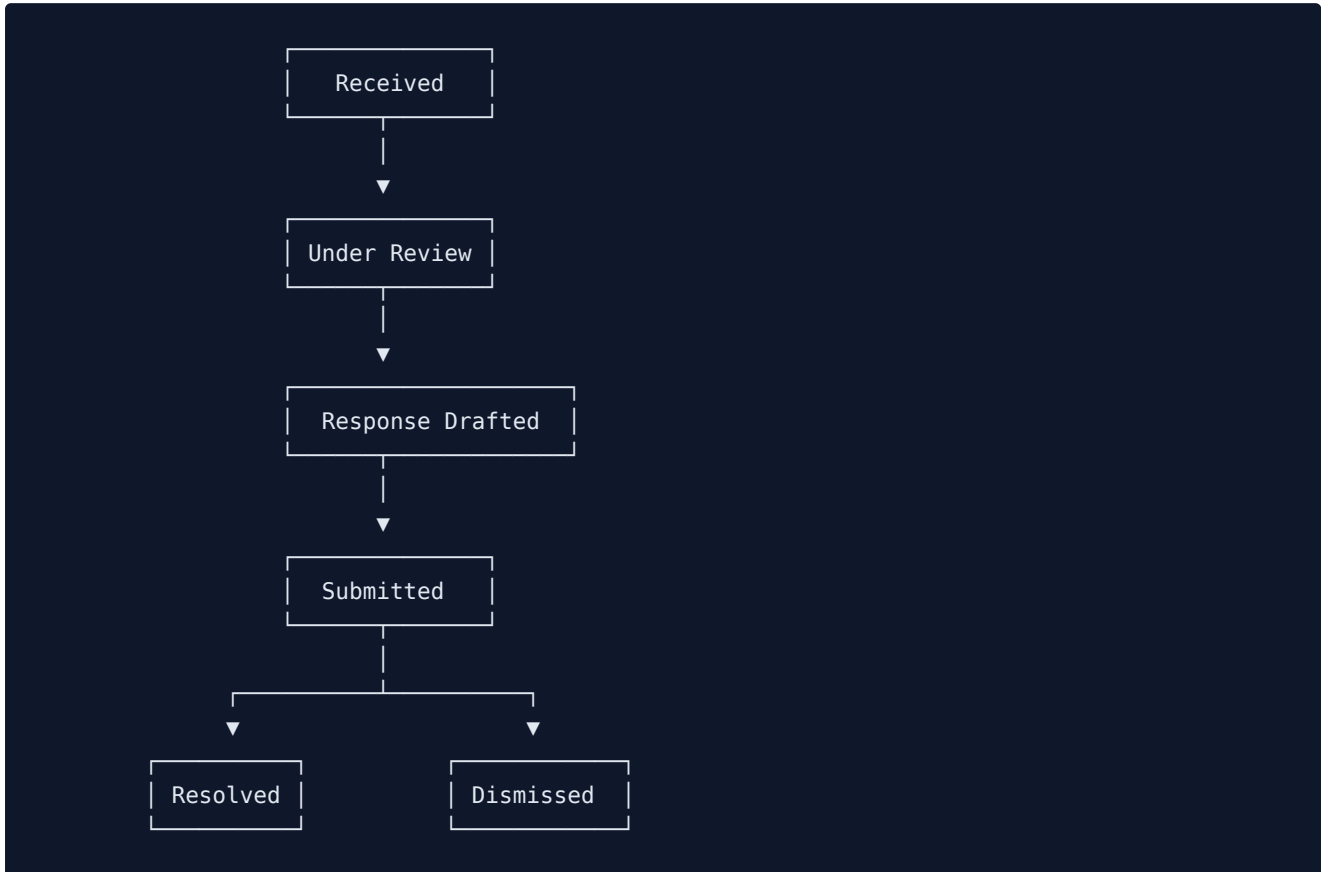
6.6 Multi-Provider Fallback

The LLM service ships with automatic provider fallback. If the primary provider returns an error, exceeds the latency budget, or hits a rate limit, the next provider in the configured chain is tried. The fallback is silent to end users — they never see an error from a provider outage. Each call's actual provider is logged for cost attribution and operational visibility.

7. Compliance Notice Lifecycle

7.1 State Machine

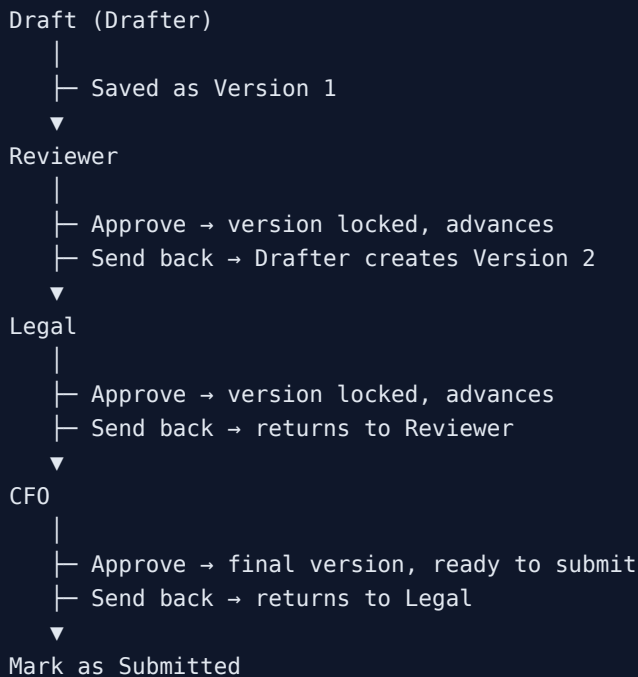
A compliance notice moves through five canonical states, with two terminal states:



Each transition is permission-gated, audit-logged, and emits a real-time WebSocket event. Backwards transitions are not allowed except by Compliance Head with explicit reason.

7.2 4-Stage Approval Workflow for Responses

Notice responses flow through up to four approval stages. Each stage has its own users, permissions, and version history.



A notice cannot reach `Submitted` unless every required stage has approved. Evidence (linked documents, supporting calculations, regulator correspondence) is attached at the response level.

7.3 Auto-Escalation Rules

When a notice scores Critical on risk:

1. The Compliance Head receives an immediate in-app and email notification
2. An escalation entry is added to the notice activity timeline
3. An audit log row records the escalation event with full forensic detail

7.4 Linked Notice Chains

Many regulatory matters span multiple notices over time. TaxSync models these as a directed graph (parent-child with `parent_notice_id`):

- Show-Cause Notice → Assessment Order → Demand Notice
- Original Demand → Stay Order → Revised Demand → Closure

A recursive Common Table Expression (CTE) returns ancestors and descendants of any notice in a single query. The chain is rendered visually on the notice detail page.

7.5 Activity Timeline

Every user-facing action on a notice is recorded as an `activity` event with:

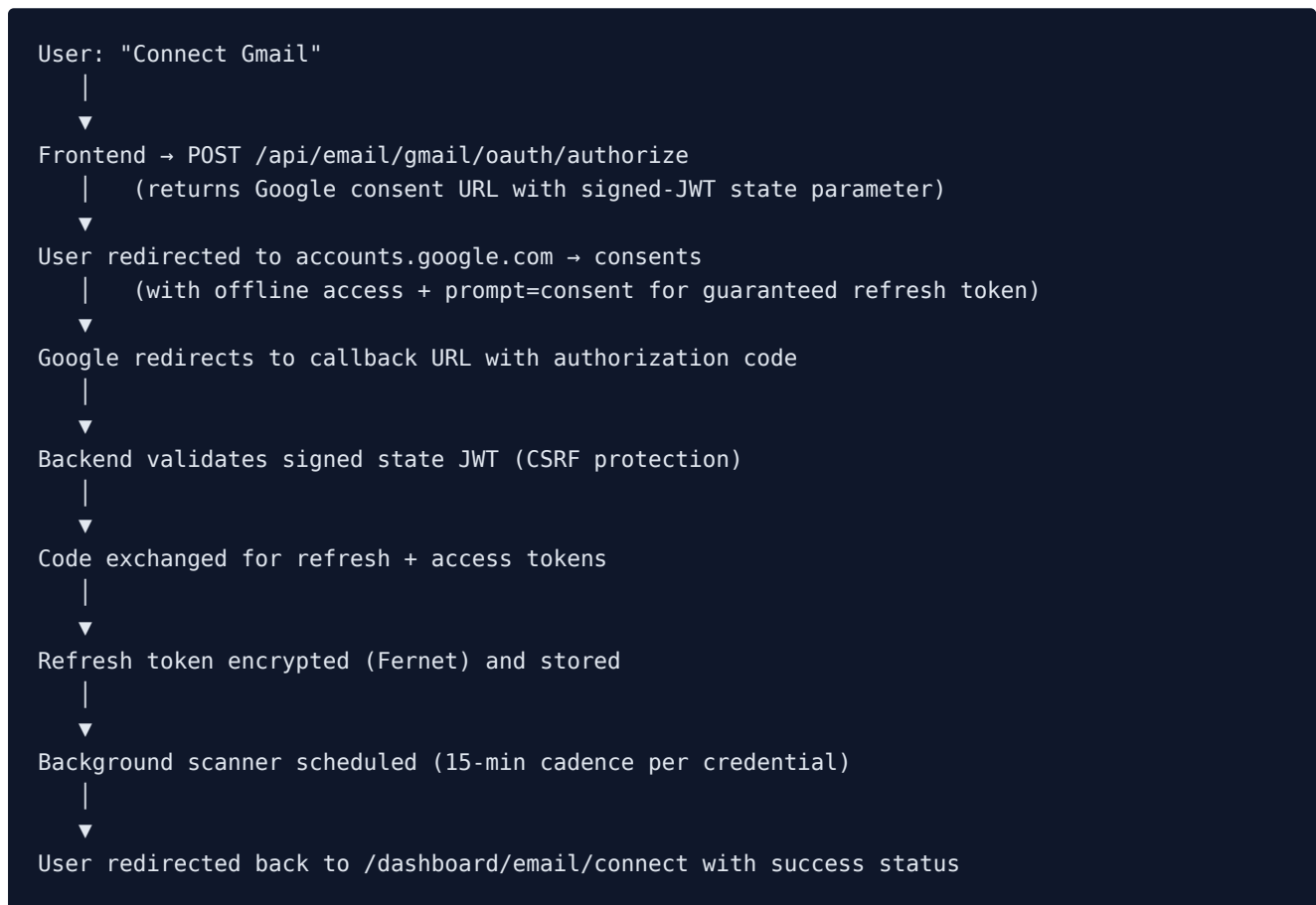
- Actor (`user_id`)
- Action type (`status_change`, `comment`, `assignment`, `attachment`, `escalation`)

- Timestamp
- Details (free-text or structured JSON)
- Visibility (compliance team only / external auditor / regulator-facing)

The activity timeline is separate from the immutable audit log. The timeline is user-facing and editable for typos; the audit log is forensically immutable.

8. Email Integration

8.1 OAuth 2.0 Connection Flow



The signed state JWT (HS256, 10-minute expiry, payload includes nonce + user_id + client_id) is the authentication of record on the cross-origin callback, since SameSite cookies are not sent on Google's redirect.

8.2 Continuous Background Scanning

A durable scheduler runs a per-credential job every 15 minutes by default (configurable from 5 minutes to 24 hours per credential). Each scan:

1. Acquires a Redis distributed lock (`SETNX` with 5-minute TTL) to prevent concurrent runs

2. Refreshes the OAuth access token if expired
3. Fetches new messages via Gmail History API (incremental sync from last `historyId`)
4. Falls back to a full message list if Gmail returns 404 (history record expired)
5. For each new message: classifies, ingests attachments, runs the document pipeline, persists structured records
6. Updates `last_history_id` for the next run
7. Releases the lock

8.3 PII Privacy Model

A core privacy principle: the email body is never persisted in raw form.

- Body lives only in a Python local variable for the duration of one scan iteration
- A SHA-256 hash of the body is stored for deduplication and audit reference
- Only sender domain (not full email address) is persisted in classification logs
- Audit log entries reference message IDs and SHA-256 hashes, never plaintext content
- "View source email" fetches the body on demand at view time and discards it on page refresh

This model means a database breach does not leak the contents of regulator notices.

8.4 Filter Rules Engine

Users can route incoming emails based on configurable rules:

- **Match by:** sender pattern (regex), subject pattern (regex), Gmail label
- **Action:** route to compliance notice, route to bill, save as document only, or ignore
- **Pre-seeded defaults:** `gov.in` domains route to compliance notices; common biller domains route to bills

Rules are evaluated in order; the first matching rule wins.

8.5 Auto-Detection Logic

Two parallel detection layers operate on every scanned message:

Detector	Rule	Outcome
Compliance	Sender domain matches a regulator pattern AND subject contains a compliance keyword	Auto-create ComplianceNotice with authority pre-filled (high confidence)
Compliance	Sender domain matches but subject does not	Route to review queue (medium confidence)
Bill	Sender domain matches a known biller pattern	Auto-create Bill record with biller name + amount + due date extracted
Default	No rule match, body $\geq$ 200 chars	Persist as Document for ML classification
Default	No rule match, body $<$ 200 chars	Ignored

8.6 Connection Health Monitoring

If two consecutive scans fail (HTTP 401 from Google means revoked refresh token, or other terminal errors):

- The credential is marked `REVOKED` in the database
- The scheduler stops retrying (no log spam)
- A "Reconnect required" banner appears in the dashboard
- An email alert is sent to the user and to the Compliance Head

9. Notifications and Alerts

9.1 Channels

Channel	Delivery
Email	SMTP via Resend (configurable to any SMTP provider)
In-App WebSocket	Redis pub/sub channel <code>notifications:{client_id}</code> , FastAPI WebSocket forwards to authenticated subscribers

9.2 Scheduled Deadline Alerts

For every compliance notice with a deadline, four jobs are scheduled in a durable PostgreSQL-backed scheduler:

Alert	Fires
<code>deadline_t7</code>	7 days before deadline
<code>deadline_t3</code>	3 days before deadline
<code>deadline_t1</code>	1 day before deadline
<code>overdue</code>	1 day after deadline if status is not Submitted

Jobs survive backend restarts (persisted in `apscheduler_jobs` table). On notice transition to `Submitted` / `Resolved` / `Dismissed`, all scheduled alerts are cancelled in O(1) by job ID.

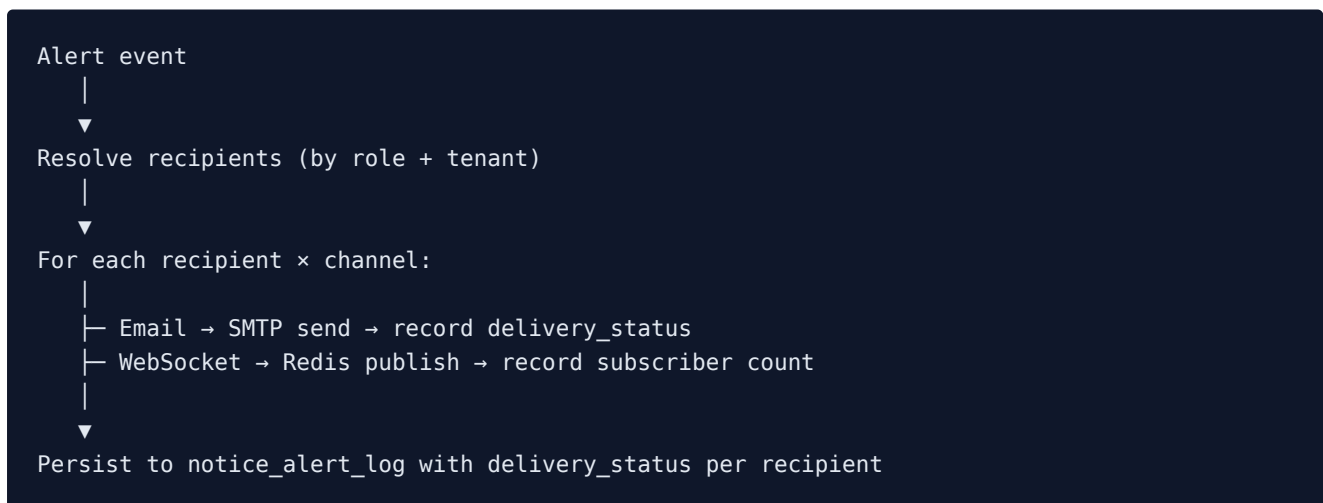
9.3 Real-Time In-App Notifications

The frontend opens a JWT-authenticated WebSocket connection on dashboard load:

- Authentication: JWT in the initial connection query string
- Authorization: server validates the user has an active `ClientMembership` for the requested `client_id`
- Auto-reconnect with exponential backoff (capped at 30 seconds)
- Membership re-validation every 60 seconds — auditors whose access window expires mid-session are disconnected automatically
- Per-client subscription: switching clients reopens the socket with new `client_id`

9.4 Pub/Sub Routing

Alert dispatch follows a fan-out pattern:



A future caller can audit any alert: who was supposed to receive it, on what channels, with what delivery outcome.

10. Security and Compliance

10.1 Multi-Tenant Isolation (Row-Level Security)

PostgreSQL Row-Level Security policies are applied to every client-scoped table with `FORCE ROW LEVEL SECURITY`. The application connects as a runtime database role (`app_runtime`) that:

- Has READ/WRITE on operational tables, subject to RLS
- Has REVOKE on `audit_logs` (cannot UPDATE or DELETE)

A `cross_client_view` PERMISSIVE policy lets senior roles see aggregated data across the clients they belong to, without leaking unauthorized clients.

10.2 Immutable Audit Trail

The `audit_logs` table has:

- A trigger that raises EXCEPTION on any UPDATE or DELETE
- `REVOKE ALL ON audit_logs FROM app_runtime` so the application role literally cannot modify rows
- INSERT-only access, ensuring append-only semantics

This is stronger than soft-delete or version columns — even a compromised application cannot tamper with the audit chain.

The trigger has a real consequence for user deletion: a hard `DELETE FROM users` would cascade `ON DELETE SET NULL` on `audit_logs.user_id`, which is an UPDATE that trips the trigger. The product instead performs soft-delete + PII anonymization: email becomes `deleted-{id}-{epoch}@deleted.local`, username and full name are anonymized, hashed_password is nulled, freeing the unique slots for re-registration while preserving forensic linkage in the audit log.

10.3 Encryption at Rest

Field	Algorithm	Notes
GSTIN	Fernet (AES-128 CBC + HMAC)	Per-client encryption key
PAN	Fernet	Per-client encryption key
Refresh tokens (Gmail)	Fernet	Tokens stored in <code>gmail_credentials</code>
User refresh tokens	Opaque hashed	Database stores hash, not plaintext
Passwords	bcrypt	passlib with adaptive cost factor

10.4 Authentication and Session Management

- **Access tokens:** JWT (HS256, 30-minute expiry) with `jti` claim for replay protection

- **Refresh tokens:** Opaque, with rotation on every use and reuse detection (a revoked token presented again revokes ALL tokens for that user)
- **Row-level locking** on token rotation prevents concurrent rotation race conditions
- **Type validation** on every token (access vs refresh) prevents token-type confusion attacks
- **Auto-logout** after configurable inactivity period

10.5 OAuth Single Sign-On

Provider	Flow	CSRF protection
Google	OAuth 2.0 authorization code	Signed state JWT (HS256, 10-min expiry)
Microsoft	OAuth 2.0 authorization code	Signed state JWT
Gmail (separate)	OAuth 2.0 with offline access	Signed state JWT

OAuth buttons render unconditionally on `/login` and `/register`. If credentials are not configured, clicking shows a helpful toast; the OAuth flow is fully gated server-side, so there is no client-side error escape path.

10.6 Rate Limiting and DDoS Protection

Endpoint class	Limit
Login, register, password operations	5 requests/minute per IP
Search	30 requests/minute per user
Document upload	60 requests/minute per user
General API	120 requests/minute per user

Rate limits are stored in Redis with an in-memory fallback if Redis is briefly unavailable. The IP for rate limiting ignores `X-Forwarded-For` to prevent IP spoofing.

10.7 HTTP Security Headers

Header	Value
Strict-Transport-Security	max-age=63072000; includeSubDomains; preload (2 years)
Content-Security-Policy	frame-ancestors 'none' , no unsafe-eval , no unsafe-inline for scripts
X-Frame-Options	DENY
X-Content-Type-Options	nosniff
Cross-Origin-Resource-Policy	cross-origin
Cache-Control	no-store on API responses

10.8 Input Validation and File Safety

- **Pydantic v2** schema validation on every request body
- **Email regex** validation with lowercase normalization
- **Username** restricted to `[a-zA-Z0-9_-]`
- **Passwords** require minimum 8 characters with at least one uppercase, lowercase, digit, and special character
- **File upload** extension whitelist, 50 MB size limit, magic-byte signature validation (uploaded files are checked against expected file signatures, not just extension — prevents disguised file uploads)
- **Streaming upload** prevents memory-DoS on large files
- **SQL injection** prevented by SQLAlchemy ORM parameterized queries
- **Path traversal** prevented by `realpath` + prefix validation in storage service

10.9 OWASP Top 10 Coverage

OWASP risk	TaxSync mitigation
A01 Broken Access Control	RLS at database, role-permission matrix at application, time-bound auditor windows
A02 Cryptographic Failures	bcrypt for passwords, Fernet for sensitive fields, HTTPS-only with HSTS
A03 Injection	ORM parameterized queries, magic-byte file validation, Pydantic input validation
A04 Insecure Design	Immutable audit log via DB trigger + REVOKE (not just app-layer)
A05 Security Misconfiguration	Strict security headers, no <code>unsafe-eval</code> in CSP, explicit CORS allowlist
A06 Vulnerable Components	Dependabot, automated dependency CI
A07 Authentication Failures	Refresh token rotation with reuse detection, rate limiting on auth, OAuth state CSRF
A08 Software and Data Integrity	Signed JWT state on OAuth, content-type validation, integrity checksums on documents
A09 Logging and Monitoring	Structured JSON logs with correlation IDs, immutable audit log, audit-failure dead-letter file
A10 Server-Side Request Forgery	Outbound HTTP only to allowlisted providers, no user-controlled URLs in server-side fetches

11. Role-Based Access Control

11.1 Role Model

TaxSync defines 7 compliance roles plus Auditor:

Role	Scope	Typical user
Compliance Head	Senior in-house owner of regulatory matters	Tax Director, VP Compliance
CA Consultant	External Chartered Accountant managing many clients	CA firm partner
CFO	Final approver on responses with material financial impact	Chief Financial Officer
Drafter	Writes the first version of a response	Tax associate
Reviewer	Peer reviews a draft before Legal	Senior associate
Legal Team	Legal accuracy and regulation citations	In-house legal counsel
Finance Team	Tax-specific notice review and reconciliation	Finance Manager
Auditor (special)	Time-bound, read-only access for inspection	External auditor, regulator

11.2 Permission Matrix

12 distinct permissions are mapped across the 7 compliance roles, producing an 84-cell decision matrix. Permissions include:

- `NOTICE_VIEW`
- `NOTICE_CREATE`
- `NOTICE_EDIT`
- `NOTICE_REVIEW`
- `NOTICE_DRAFT_RESPONSE`
- `NOTICE_APPROVE_LEGAL`
- `NOTICE_APPROVE_CFO`
- `NOTICE_SUBMIT`
- `EMAIL_INTEGRATION_USE`
- `REPORT_VIEW`
- `AUDIT_VIEW`
- `MEMBERSHIP_MANAGE`

The permission registry is a single source of truth; every API endpoint and UI component checks against it. The 84-cell matrix is verified by parametrized test fixtures.

11.3 Time-Bound Auditor Access

Auditors receive a `ClientMembership` row with `access_end` set to a configured expiry date:

- The `is_membership_active(membership)` helper returns False after `access_end`

- WebSocket connections re-validate every 60 seconds — auditors mid-session are disconnected when their window closes
- A countdown banner shows the auditor how many days remain
- Read-only enforcement is at the permission level (auditor role grants only `*_VIEW` permissions)

11.4 Cross-Client View

Senior roles (Compliance Head, CA Consultant, CFO) can see aggregated data across all clients they belong to:

- The `cross_client_view` PostgreSQL PERMISSIVE policy allows multi-client SELECTs for these roles
- The `X-Client-Id` HTTP header accepts a sentinel value (`*`) for cross-client mode
- All other roles see only the active client; cross-client mode is silently downgraded if attempted

12. Statutory Calendar

12.1 Pre-Loaded Deadlines

37 statutory deadlines for FY 2025-26 are pre-seeded:

Authority	Deadline examples
GST	GSTR-1 (monthly), GSTR-3B (monthly), GSTR-9 (annual), GSTR-9C (annual)
Income Tax	Advance Tax instalments (4×), TDS quarterly returns (4×), ITR filings
MCA	Annual filings, AOC-4, MGT-7
RBI	Reporting circulars by category
SEBI	Quarterly disclosures

12.2 Holiday-Aware Adjustment

When a deadline falls on:

- **Sunday** → shift to next Monday
- **Gazetted holiday** (Indian holiday calendar) → shift to next working day
- **Both** → cascade through the calendar to the next working day

The system shows the original date alongside the adjusted date so users understand why an alert is firing. Penalty calculations use the adjusted date.

12.3 Compliance Health Score

A single percentage shown at the top of every client dashboard, calculated over a rolling 90-day window:

```
health_score = 100 × (
  (notices_responded_on_time / total_notices)
  + (1 - average_response_time_factor)
  + (1 - overdue_count_factor)
) / 3
```

Higher means fewer overdue notices and faster response times. The breakdown (% on time, average response time, overdue count) is visible on hover.

13. API Reference

A summary of the major REST endpoints. All endpoints (except auth) require `Authorization: Bearer <token>`. Compliance endpoints additionally require the `X-Client-Id` tenant header.

13.1 Authentication

Method	Endpoint	Description
POST	<code>/api/auth/register</code>	Create account
POST	<code>/api/auth/login</code>	Get access + refresh token pair
POST	<code>/api/auth/refresh</code>	Rotate refresh token
POST	<code>/api/auth/logout</code>	Revoke refresh token
GET	<code>/api/auth/providers</code>	List configured auth providers
GET	<code>/api/auth/oauth/google</code>	Google OAuth URL
GET	<code>/api/auth/oauth/microsoft</code>	Microsoft OAuth URL
POST	<code>/api/auth/oauth/exchange</code>	Exchange OAuth code for tokens

13.2 Documents

Method	Endpoint	Description
POST	<code>/api/documents/upload</code>	Upload file (returns 202, async processing)
GET	<code>/api/documents/{id}/status</code>	Poll processing status
GET	<code>/api/documents/all</code>	List all documents (paginated)
GET	<code>/api/documents/{id}</code>	Get document detail
GET	<code>/api/documents/search</code>	Full-text search with optional category filter
GET	<code>/api/documents/category/{cat}</code>	Filter by category
GET	<code>/api/documents/stats</code>	Dashboard statistics
DELETE	<code>/api/documents/{id}</code>	Delete document and file
POST	<code>/api/documents/{id}/share</code>	Share with a user (Viewer / Editor / Admin)
GET	<code>/api/documents/shared-with-me</code>	List documents shared with current user

13.3 Compliance Notices

Method	Endpoint	Description
GET	<code>/api/compliance/notices</code>	List/filter notices for active tenant
POST	<code>/api/compliance/notices</code>	Create notice with manual metadata
GET	<code>/api/compliance/notices/{id}</code>	Get notice detail
PATCH	<code>/api/compliance/notices/{id}</code>	Edit metadata
PATCH	<code>/api/compliance/notices/{id}/status</code>	State machine transition
POST	<code>/api/compliance/notices/bulk</code>	Bulk status update with partial-failure semantics
GET	<code>/api/compliance/notices/{id}/chain</code>	Recursive ancestors and descendants
POST	<code>/api/compliance/notices/{id}/upload</code>	Attach PDF/JPG/PNG; dispatches OCR + classification
GET	<code>/api/compliance/notices/{id}/activity</code>	User-facing timeline

13.4 Compliance Reporting

Method	Endpoint	Description
POST	/api/compliance/reports/health-summary	Monthly summary (JSON)
POST	/api/compliance/reports/health-summary/export	Same as above (CSV)
GET	/api/compliance/reports/penalty-by-authority	Aggregation (JSON or CSV)
GET	/api/compliance/reports/notice-volume-by-status	Aggregation (JSON or CSV)
GET	/api/compliance/reports/response-time	Percentile stats (JSON or CSV)
GET	/api/compliance/search/unified	FTS across notices and documents

13.5 Compliance Operational

Method	Endpoint	Description
GET	/api/compliance/clients/me	Tenants the current user has membership on
GET	/api/compliance/audit	Read-only audit log
GET	/api/compliance/calendar/entries	37 statutory deadlines (filterable)
GET	/api/compliance/calendar/compliance-score	Rolling 90-day health score
GET	/api/compliance/review/pending	ML review queue
POST	/api/compliance/responses	Create draft response
PATCH	/api/compliance/responses/{id}/transition	4-stage approval transition

13.6 Email Integration

Method	Endpoint	Description
POST	/api/email/gmail/oauth/authorize	Get Google consent URL
GET	/api/email/gmail/oauth/callback	OAuth callback handler
GET	/api/email/credentials	List connected Gmail credentials
DELETE	/api/email/credentials/{id}	Disconnect a credential
GET	/api/email/filter-rules	List filter rules
POST	/api/email/filter-rules	Add a filter rule
GET	/api/email/bills	List detected bills
GET	/api/email/activity	Scan history and outcomes

13.7 Real-Time

Method	Endpoint	Description
WS	/ws/notifications?token=<jwt>&client_id=<id>	JWT-authenticated WebSocket subscription

13.8 Admin

Method	Endpoint	Description
GET	/api/admin/users	List all users
GET	/api/admin/stats	Admin dashboard statistics
PATCH	/api/admin/users/{id}/role	Update user role
PATCH	/api/admin/users/{id}/status	Update user status
DELETE	/api/admin/users/{id}	Soft-delete with PII anonymization
GET	/api/admin/audit	Query audit logs (filterable)

14. Deployment Architecture

14.1 Container Topology

A single `docker compose up` brings up the entire stack:

Service	Image	Memory ceiling	Purpose
<code>db</code> (development)	<code>postgres:16-alpine</code>	512 MB	Local PostgreSQL with trigger DDL support
<code>redis</code>	<code>redis:7-alpine</code>	256 MB	Celery broker, pub/sub, rate limiter
<code>backend</code>	Built from <code>./backend</code>	1 GB	FastAPI app server
<code>celery_worker</code>	Built from <code>./backend</code>	1 GB	Default queue (OCR, document pipeline)
<code>compliance_worker</code>	Built from <code>./backend</code>	2.5 GB	Compliance queue (BERT, spaCy, risk scoring)
<code>frontend</code>	Built from <code>./frontend</code>	512 MB	Next.js standalone server

Production uses the same images with `db` swapped for managed PostgreSQL (Supabase Cloud or equivalent) via `DATABASE_URL` override.

14.2 Environment Variables

Critical configuration:

Key	Purpose
<code>SECRET_KEY</code>	JWT signing (≥32 chars, cryptographically random)
<code>DATABASE_URL</code>	PostgreSQL connection (session-mode pooler required for RLS)
<code>REDIS_URL</code> , <code>REDIS_PASSWORD</code>	Broker and cache
<code>CELERY_BROKER_URL</code> , <code>CELERY_RESULT_BACKEND</code>	Task queue
<code>GOOGLE_CLIENT_ID</code> , <code>GOOGLE_CLIENT_SECRET</code>	Google OAuth (login + Gmail)
<code>MICROSOFT_CLIENT_ID</code> , <code>MICROSOFT_CLIENT_SECRET</code>	Microsoft OAuth
<code>EMAIL_OAUTH_REDIRECT_URI</code>	Must match Google Console authorized redirect URI
<code>SMTP_HOST</code> , <code>SMTP_PORT</code> , <code>SMTP_USERNAME</code> , <code>SMTP_PASSWORD</code> , <code>SMTP_FROM_EMAIL</code>	Email delivery
<code>LLM_PROVIDER</code> , <code>LLM_MODEL</code>	Primary LLM provider
<code>OLLAMA_BASE_URL</code>	Local LLM endpoint
<code>FRONTEND_URL</code> , <code>BACKEND_URL</code>	Cross-origin and OAuth redirects
<code>ALLOWED_ORIGINS</code>	CORS allowlist (production: exact domain only)
<code>DEBUG</code>	<code>false</code> in production
<code>AUDIT_FAILURES_PATH</code>	Durable path for audit-write dead-letter JSONL

14.3 Database Hosting

- **Production:** Supabase Cloud, session-mode pooler on port 5432 (transaction-mode pooling does not support RLS context vars)
- **Development:** Local PostgreSQL 16 in Docker (required for trigger DDL, CREATE ROLE, FORCE ROW LEVEL SECURITY tests)
- **Migrations:** Alembic with linear, idempotent revision history
- **Backups:** Managed by Supabase (point-in-time recovery, daily snapshots)

14.4 CI/CD Pipeline

GitHub Actions:

- Automated test suite on every push and pull request
- Linting and type checking
- Docker image build on merge to main
- Dependabot pull requests for dependency updates
- Preview deployments via Vercel for frontend changes
- Production frontend deployment on merge to main

14.5 Monitoring and Logging

- **Structured JSON logs** with correlation IDs across services
- **PII redaction** in log output (regex-based, applied at structlog processor)
- **Per-container log rotation** (10 MB per file, 3 files retained)
- **Audit failure dead-letter** persisted to a named volume so a regulatory event during a database outage is recoverable
- **Health checks** per service with start_period and retry policies
- **Metrics endpoints** ready for Prometheus / Grafana scrape

15. Performance and Reliability

15.1 Document Processing

Metric	Target	Achieved
API response on upload	< 200 ms (returns 202)	Achieved (no synchronous OCR on the request path)
OCR + classification per document	< 30 seconds typical	Achieved on test corpus
Classifier accuracy	≥ 85% on held-out set	85.06% achieved
Concurrent documents per worker	2 (configurable)	Achieved with <code>--max-memory-per-child=512000</code>

15.2 Compliance Pipeline

Metric	Target	Achieved
Gmail scan cadence	5-1440 minutes per credential	Achieved, configurable
Notice creation latency (after Gmail fetch)	< 5 seconds	Achieved
Deadline alert firing accuracy	±1 hour (misfire grace 1 hour)	Achieved via APScheduler
WebSocket reconnect time	< 30 seconds	Achieved with exponential backoff cap

15.3 Database

- **Connection pool** sized to per-service ceiling
- **Pool overflow** logged and alerted
- **SSL** enforced on all production database connections
- **PgBouncer / Supabase pooler** in session mode (RLS-compatible)

15.4 Caching

Cached object	TTL	Backing store
Gmail access tokens	until expiry	Redis
Rate limit counters	1 minute	Redis (in-memory fallback)
Frequent reports	configurable	Redis
Tenant context per request	request scope	In-process

15.5 Backup and Recovery

- **Database:** Supabase managed point-in-time recovery + daily snapshots
- **Object storage:** Versioned bucket with lifecycle rules
- **Audit failure dead-letter:** Persisted to durable named volume; replayed on next successful database connection
- **Disaster recovery RPO:** < 24 hours (daily snapshots)
- **Disaster recovery RTO:** < 4 hours (managed restore + container redeploy)

16. Quality Assurance

16.1 Test Coverage

- 389 backend automated tests covering authentication, document pipeline, compliance state machine, RLS isolation, audit immutability, RBAC matrix, alert dispatch, Gmail scanner, response workflow, and search
- 63 test files organized by module
- Parametrized RBAC matrix: 84 role × permission cells verified in a single test fixture
- Frozen-time fixtures: Deadline alerts, time-bound auditor windows, and refresh token expiry tested with deterministic time

16.2 Security Audit Outcomes

The platform has been hardened through multiple comprehensive security audits:

Audit	Outcome
Initial security audit	21 fixes across 17 files (OAuth CSRF, token rotation, rate limiter IP spoofing, security headers, input validation)
Authentication and login fixes	11 bugs fixed (database connection, Redis fallback, cookie expiry, OAuth response safety, token rotation ordering)
Comprehensive security hardening	25 fixes across 14 files (password complexity, magic byte file validation, streaming upload, CSP hardening, server-side route protection, JWT jti claims, OAuth timing-safe comparison, CORS validation, DB SSL, Celery rate limiting)

16.3 Code Review Process

- Mandatory pull request review for changes to security-critical paths
- Automated linting and type checking in CI
- Structured logging review to ensure no PII leakage
- Schema change review for migration safety (online migrations preferred)

17. Glossary

Term	Definition
GSTIN	A unique 15-character ID issued to a business under Goods and Services Tax. A tax-ID for a specific GST registration.
PAN	Permanent Account Number. A 10-character ID from Income Tax that identifies a person or entity.
CIN	Corporate Identification Number. A 21-character code for a company registered with the MCA.
GST	Goods and Services Tax. The federal indirect tax in India.
TDS	Tax Deducted at Source. Tax withheld at the time of payment (salary, contractor fees, rent over a threshold).
ITR	Income Tax Return. Annual filing with the Income Tax department.
MCA	Ministry of Corporate Affairs. Regulator for companies.
RBI	Reserve Bank of India. Banking and forex regulator.
SEBI	Securities and Exchange Board of India. Capital markets regulator.
Notice	A formal communication from a regulator demanding information, payment, or response by a deadline.
Show-Cause Notice	A notice asking the recipient to explain why a proposed action (penalty, demand) should not be taken.
Compliance Head	The senior in-house owner of regulatory matters. Typically approves the most serious responses.
CA Consultant	A Chartered Accountant external to the client, often managing many clients across many GSTINs.
CFO	Chief Financial Officer. Final approver on responses with material financial impact.
Drafter	The team member who writes the first version of a response.
Reviewer	The peer who reviews a draft before it goes to Legal.
Legal Team	The team responsible for legal accuracy and regulation citations in a response.
Finance Team	Reviewers of tax-specific notices and reconciliation data.
Auditor	An external party with time-bound, read-only access for inspection or assurance work.
Audit Trail	A tamper-proof, timestamped record of who did what, when.

Term	Definition
Risk Tier	A label (Critical, High, Medium, Low) summarizing how urgent a notice is.
OAuth	A standard authorization flow used to connect a Google or Microsoft account safely without sharing a password.
OCR	Optical Character Recognition. Reading text from images and scanned documents.
RLS	Row-Level Security. A PostgreSQL feature that filters rows at the database level, not the application level.
TF-IDF	Term Frequency-Inverse Document Frequency. A text-vectorization technique used to convert documents into numeric features for ML.
SHAP	A method for explaining the contribution of each input feature to a model's output.